

E-Rakshak 2026 — PS-4

Unified Cross-Platform Malware Detection and Behavioral Analysis Suite

Round 2 Execution Plan | Neil Banerjee | Rank 6 Qualifier

4-Week Plan

08 July 2026 — 30 July 2026

1. Problem Understanding

ERH26_PS_04 — Domain: Cybersecurity & Malware Analysis

Police departments deal with endpoints compromised by spyware, RATs, and malicious APKs (light-bill fraud, loan-app scams, fake e-Challan schemes). Investigators need a safe, localized environment to scan a suspect/victim device, identify exactly what data is being stolen and where it's being sent, across both Windows and Android, with a report a non-technical officer can read.

Core functional blocks (from the PS)

Block	What it covers
Static Analysis	Hashing, YARA/signature matching, APK manifest & permission scan, PE inspection, string/URL/IP extraction
Dynamic / Sandbox Analysis	Detonate in isolation, capture API/syscalls, network traffic (C2/exfil), track file/registry/SMS/contact access
Behavioral Profiling	Classify capability (keylogging, OTP theft, screen capture, GPS tracking), map to MITRE ATT&CK, plain-language summary
Reporting & IOCs	Exportable CSV/STIX, evidence-grade hash-chained logging

Bonus points explicitly named in the PS

- Automated MITRE ATT&CK mapping
- Encrypted-traffic behavioral analysis (metadata-based, no decryption)
- Threat-intel feed enrichment of discovered IOCs
- **Offline / air-gapped operation** for sensitive samples

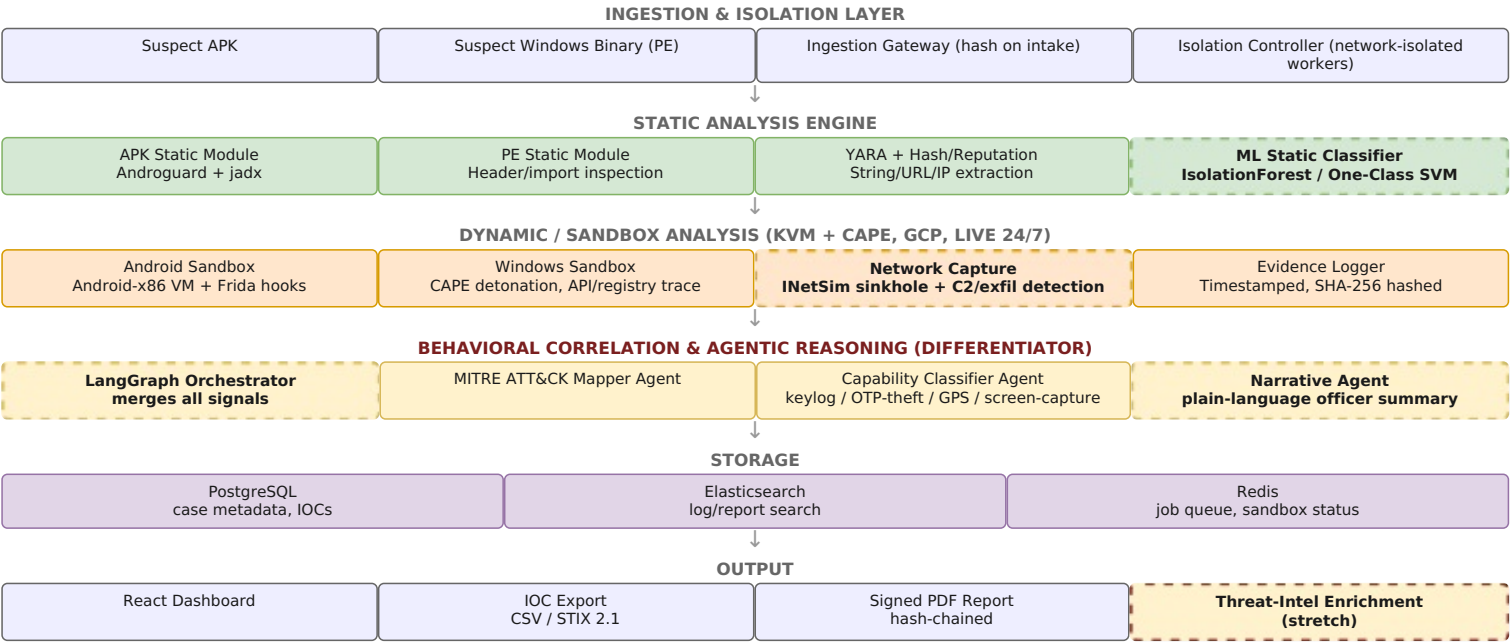
2. Differentiation Strategy (4-5 teams on same PS)

Most teams will build the obvious read: YARA + a Cuckoo clone + a dashboard. That's table stakes. The wedge is in what happens *after* detection — correlation and communication.

Generic team approach	Our approach
Separate Windows tool + separate Android tool	One unified pipeline, same UI, same report format for both platforms
Raw JSON dump as "report"	LangGraph agent chain correlating static + dynamic + network signals into a narrative
Manual or no MITRE tagging	Auto MITRE ATT&CK mapping agent
Report reads like a log file	Plain-language narrative agent (Groq/Kimi LLM) — "this app reads your SMS OTPs and sends them to 185.x.x.x every 40s"
Online-only sandbox	Live 24/7 cloud-hosted sandbox (GCP nested virtualization + KVM/CAPE)
Ignore encrypted traffic	Metadata-based encrypted traffic analysis (JA3 fingerprinting, timing/size patterns) — stretch goal

Priority order: (1) LangGraph correlation + narrative agent, (2) unified Windows+Android pipeline, (3) 24/7 live sandbox deployment, (4) encrypted-traffic analysis as stretch if time allows.

3. Architecture



Dashed boxes = differentiator features vs. other PS-4 teams. Full editable diagram delivered separately as PS4_Architecture.drawio.

4. Deployment: Two-Plane Architecture (Live 24/7, Free of Cost)

A cloud VM running Cuckoo/CAPE means a VM *inside* a VM (nested virtualization) — most affordable hosts block this or ban malware execution outright by ToS. Split into two planes:

Control Plane (public-facing, judges access this)

Dashboard, API, DB, agent orchestrator, report generation — deployed normally, reverse-proxied via Nginx + Let's Encrypt on port 443 only. No malware ever touches this layer.

Detonation Plane (isolated, does the actual malware execution)

- **Host:** Google Cloud Compute Engine, `n2-standard-4` (4 vCPU / 16GB), Ubuntu 22.04, nested virtualization flag enabled at creation
- **Cost:** \$0 — new Google account gets \$300 free trial credit for 90 days; entire hackathon timeline costs ~\$30-50 of that
- **Hypervisor:** KVM/QEMU (not VirtualBox — VirtualBox is GUI-first and unreliable headless on a server)
- **Sandbox engine:** CAPE (free, open source), natively supports KVM/libvirt, auto-reverts Windows 10 golden snapshot after every detonation
- **Android side:** Android-x86 as a second QEMU VM on the same host, Frida server pre-installed for instrumentation hooks
- **Network containment:** All victim-VM traffic routed through INetSim (fake DNS/HTTP/SMTP sinkhole) — captures "tried to call 185.x.x.x:4444" for the report without ever letting traffic actually reach the real internet. Manual, logged, rate-limited exception only if a real C2 endpoint needs verification.
- **Exposure:** Only the Control Plane's port 443 is public. Hypervisor/detonation management is SSH-only, never public.

5. Week-Wise Plan (Wed 08 Jul → Thu 30 Jul)

Week 1 2 DAYS

Wed 08 Jul — Thu 09 Jul (ends at tomorrow's meeting)

- Lock scope: confirm the 2-3 differentiators actually being committed to — **All**
- Finalize architecture (Section 3), assign roles — static owner, sandbox owner, agent-layer owner, frontend owner — **All**
- Set up repo, Docker skeleton — **Neil**
- Create Google Cloud account, claim \$300 trial credit, spin up the `n2-standard-4` instance with nested virtualization enabled — **Member 2**
- Line up 3-5 real sample sources (test APKs + known RAT/PE samples — MalwareBazaar, theZoo) — **Neil**

Week 2 7 DAYS

Fri 10 Jul — Thu 16 Jul

- Static analysis engine: hashing, YARA rule set, Androguard/jadx for APK manifest+permissions, PE header/import inspection — **Member 1**
- String/URL/IP extraction working end-to-end on both platforms — **Member 1**
- Ingestion gateway + isolation controller (Docker network-isolated workers) — **Member 2**
- Install KVM + CAPE on the GCP box, build Windows 10 golden snapshot with CAPE agent baked in — **Member 2**
- LangGraph orchestrator skeleton against mock static-analysis output; early MITRE mapping scaffolding — **Neil**

Milestone (Thu 16 meeting): static pipeline demo on 1 APK + 1 PE sample; CAPE detonating on the live GCP sandbox

Week 3 7 DAYS

Fri 17 Jul — Thu 23 Jul

- Android-x86 QEMU VM + Frida hooks (SMS/contacts/location access tracking) — **Member 2**
- Windows dynamic: API/registry/file call tracing via CAPE — **Member 2**
- INetSim network sinkhole wired in — exfil endpoint / C2 detection without real internet exposure — **Member 2**
- Start LangGraph orchestrator wiring static + dynamic outputs together — **Neil**

Milestone (Thu 23 meeting): full detonate-and-capture demo on both platforms, live on the 24/7 GCP sandbox

Week 4 7 DAYS

Fri 24 Jul — Thu 30 Jul

- MITRE ATT&CK mapping agent + capability classifier agent — **Neil**
- Plain-language narrative agent (Groq/Kimi LLM) — the standout feature, spend real time here — **Neil**
- React dashboard wiring everything together, IOC export (CSV/STIX) — **Member 4**
- Dashboard additions (near-free, using data already generated): Process Tree view, Risk Score (0–100 weighted from static+dynamic+MITRE signals), Evidence Timeline — **Member 4**
- Stretch dashboard additions if time allows: Geo-IP Map (foreign vs domestic exfil visualization — strengthens India-angle), AI Recommendations (extend narrative agent to suggest next investigative steps), Malware Family tag (surface matched YARA/family label, not real ML classification) — **Member 4 + Neil**
- Buffer for bug fixing, demo script, documentation — **All**
- Stretch if time allows: encrypted-traffic metadata analysis, threat-intel enrichment — **Member 1 / Member 2**

Milestone (Thu 30, final): full submission-ready demo — complaint sample in, correlated behavioral report with MITRE mapping and plain-language summary out

6. Team Task Division (4 members)

Split along the four pipeline layers so each person owns one vertical slice end-to-end, not one task per week — avoids everyone blocking on everyone else.

Member 1 — Static Analysis & ML *(APK + PE static engine)*

- Hashing, YARA rule set, reputation lookup
- Androguard/jadx for APK manifest & permission analysis
- PE header/import inspection for Windows binaries
- String/URL/IP extraction
- ML static classifier (IsolationForest / One-Class SVM) — stretch differentiator

Member 2 — Dynamic Sandbox & Cloud Infra *(the deployment-heavy role)*

- GCP setup: instance, nested virtualization, networking, security groups
- KVM/QEMU + CAPE install, Windows 10 golden snapshot with CAPE agent
- Android-x86 QEMU VM + Frida instrumentation
- INetSim network sinkhole for contained C2/exfil capture
- Evidence logger (timestamped, SHA-256 hashed)

Member 3 — Agent Layer & Behavioral Reasoning *(the differentiator — likely Neil, LangGraph background)*

- LangGraph orchestrator wiring static + dynamic + network signals together
- MITRE ATT&CK mapping agent
- Capability classifier agent (keylogging / OTP theft / GPS / screen capture)
- Plain-language narrative agent (Groq/Kimi LLM) — the standout report feature

Member 4 — Dashboard, Reporting & Storage *(frontend + data layer)*

- React dashboard: case view, behavioral report display, live sandbox status
- PostgreSQL schema (case metadata, IOCs), Elasticsearch (log/report search), Redis (job queue)
- IOC export (CSV / STIX 2.1), signed PDF report generation
- **Chain of Custody module** as its own visible dashboard tab — not just a backend feature, must be demoable (police-specific differentiator)
- Process Tree view, Risk Score, Evidence Timeline — near-free additions surfacing data already generated by the pipeline
- Stretch: Geo-IP Map, AI Recommendations, Malware Family tag
- Demo script + documentation compilation in Week 4

Weekly sync point: every Thursday meeting, each member demos their slice against the same sample so integration gaps surface early instead of in Week 4.

Architecture diagram also delivered as an editable file: PS4_Architecture.drawio